

h4ck3d X Security Conference

Manual del Workshop

Hands-on Cyber OT

h4ck3d X 2026 · Universidad de Palermo + Securetia

Este manual reúne las prácticas guiadas del workshop. Cada práctica combina un breve repaso teórico con ejercicios paso a paso sobre el simulador local, las capturas de tráfico y el equipamiento del laboratorio. La teoría completa de cada bloque se encuentra en las diapositivas; en este documento el énfasis está puesto en la ejercitación práctica.

Cómo usar este manual

El manual está organizado en prácticas. Todas siguen la misma estructura y emplean las siguientes convenciones:

- **Objetivo:** el propósito de la práctica.
- **Pasos numerados:** deben seguirse en el orden indicado.
- **Comandos:** se presentan en `monoespaciado` para copiarlos textualmente.
- **Pregunta (P#):** se responden durante el desarrollo de la práctica. Las respuestas y las orientaciones figuran en la Guía del instructor.

Reglas de trabajo

La distinción entre analizar y dañar es la que separa una evaluación profesional de un incidente. En los entornos OT, esa distinción resulta especialmente crítica.

- El trabajo se limita al alcance autorizado del laboratorio; nunca se actúa contra sistemas reales sin autorización explícita y por escrito.
- El OSINT consiste en observar: consultar información pública es admisible; iniciar sesión o interactuar con un sistema ajeno, no lo es.
- El reconocimiento activo se realiza exclusivamente contra el simulador local que cada participante ejecuta en su equipo.
- En OT, un escaneo agresivo puede dejar un equipo fuera de servicio. La demostración destructiva la realiza únicamente el instructor, sobre un equipo de sacrificio.

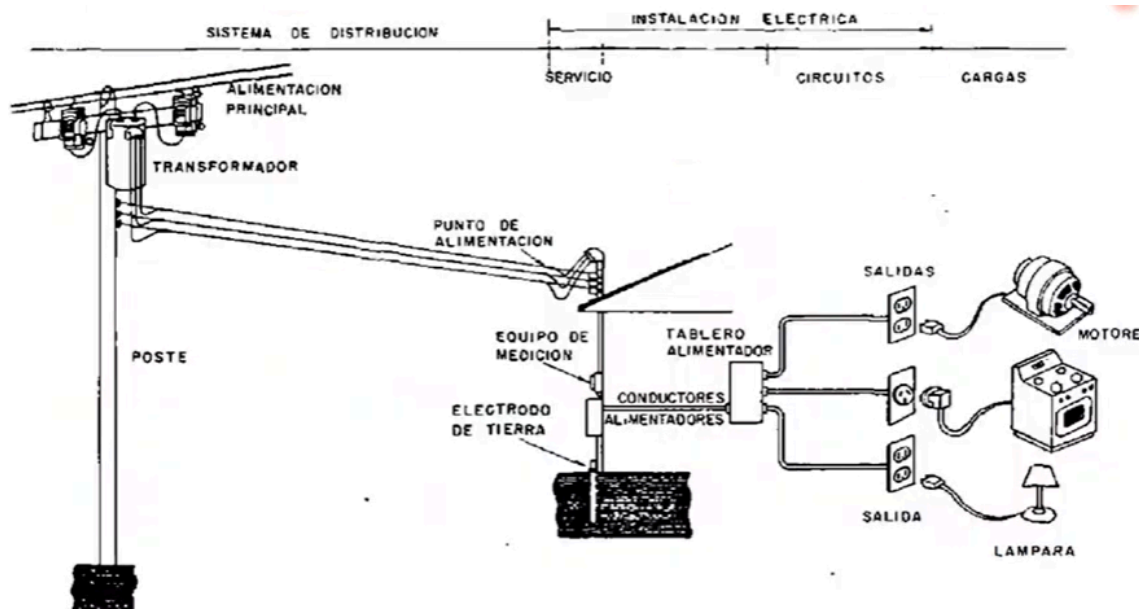
Requisitos previos

- Equipamiento liviano en el equipo personal (no se requiere una máquina virtual): Wireshark, nmap con scripts NSE, Python con `pymodbus` (que debe instalarse fijando la versión: `pip install pymodbus==3.6.9`), y un simulador Modbus liviano (por ejemplo, ModRSSim2). El conjunto ocupa pocos megabytes; véase la *Guía de preparación (Bloque 0)*.
- El conjunto de capturas (PCAP) del workshop, provisto en el repositorio.

h4ck3d X Security Conference

El escenario: DEPSA y el AL-07

DEPSA (Distribuidora Eléctrica Pampeana) es una distribuidora regional de energía. Su actividad consiste en repartir electricidad: la recibe en sus subestaciones y la conduce, mediante alimentadores de media tensión (13,2 kV), hasta los barrios. Cada alimentador es una línea que energiza una zona, y un interruptor la conecta o la corta (cerrado significa con energía; abierto, sin energía).



ALUMBRADO E INST. ELECTRICAS. (SESION 028-4.4 SIST DE ALIM DE CARGA MON...

El alimentador central del workshop es el **AL-07**, que suministra energía a un barrio en el que se encuentra un hospital. En el laboratorio, el **LOGO** modela el interruptor del AL-07: ese es el elemento que, en la Fase 3, se abrirá de forma controlada mediante una única escritura Modbus.

El control, en síntesis. DEPSA supervisa la operación desde un SCADA (WinCC); los PLC ejecutan la lógica que mantiene el interruptor cerrado; la red OT vincula el SCADA, la HMI y el PLC. Si alguien logra escribir en el PLC sin autenticación, puede abrir el interruptor y dejar sin suministro al barrio.

Nota: en una distribuidora real, los protocolos serían IEC 60870-5-104 o IEC 61850; en el workshop se emplea Modbus como sustituto didáctico. El concepto (escribir una salida sin autenticación) es el mismo, aunque más sencillo de exponer.

h4ck3d X Security Conference

Práctica 1. Reconocimiento de DEPSA (Fase 1)

Comienza la evaluación. DEPSA contrató al equipo para evaluar su entorno OT; esta es la Fase 1: reconstruir el mapa de la distribuidora antes de enviar un solo paquete. Primero mediante fuentes abiertas (OSINT) y, a continuación, mediante reconocimiento activo, aunque controlado, contra el laboratorio de DEPSA. Es la etapa que más respeta la fragilidad de los entornos OT.

Objetivo. Perfilar el entorno OT de DEPSA: identificar activos, servicios expuestos y huellas (fabricante, modelo, firmware) mediante OSINT y reconocimiento activo no intrusivo (OT-safe), y elaborar el inventario de activos del cliente.

Herramientas requeridas. Un navegador (para Shodan/Fofa y Google), una terminal, nmap (con scripts NSE), Python con pymodbus y un simulador Modbus (ModRSSim2 o el script que figura a continuación). Todo el material se detalla en la Guía de preparación del repositorio.

Parte A. OSINT pasivo (≈10 min)

El objetivo de esta parte es determinar cuánta información puede obtenerse sobre DEPSA sin enviarle un solo paquete. El cliente aportó dos insumos para comenzar: un aviso de trabajo reciente y una ficha de reconocimiento (OSINT) que su propio equipo recopiló sobre la presencia pública de la empresa. A partir de ellos, y de los motores de búsqueda de dispositivos, se amplía la información.

A.1. Motores de búsqueda de dispositivos: Shodan y FOFA

DEPSA es una distribuidora eléctrica: opera PLC Siemens y emplea Modbus, precisamente el tipo de equipo que suele quedar expuesto en Internet. Para dimensionar esa exposición se emplean dos motores de búsqueda de dispositivos, Shodan y FOFA, que indexan equipos accesibles desde Internet.

1. Acceder a shodan.io. Una cuenta gratuita permite filtrar por puerto y país; sin cuenta también se obtienen resultados básicos.

2. En la barra de búsqueda, ingresar la siguiente consulta y presionar *Enter*:

```
port:502  
product:Modbus
```

3. Ensayar también las siguientes consultas, una por una:

```
"Siemens" port:102  
"Simatic S7"  
screenshot.label:ics
```

Resultado esperado: un listado de dispositivos, cada uno con su IP, la organización o ISP, el país y un banner. Muchos son PLC o gateways reales con su puerto industrial (502 o 102) expuesto a Internet.

h4ck3d X Security Conference

4. Repetir el ejercicio en *FOFA* (fofa.info), que cumple una función equivalente a la de Shodan con una sintaxis propia basada en filtros (`protocol`, `port`, `app`, `product`) combinables con `&&` y `||`. Requiere una cuenta gratuita para ver los resultados completos. Ingresar estas consultas, una por una:

```
protocol="modbus"  
protocol="modbus" && port="502"  
"Siemens" && port="102"  
app="SIEMENS-SIMATIC-PCS7"
```

Resultado esperado: un listado equivalente al de Shodan. FOFA agrupa y resume los resultados por protocolo y producto, lo que facilita comparar la exposición de cada fabricante.

5. Seleccionar un resultado (en cualquiera de los dos buscadores) para abrir su panel de detalle y observar: *Ports* (puertos abiertos), el *banner*, el bloque *Device Identification* (en ocasiones, fabricante, modelo y firmware) y el mapa.

Advertencia. Observar no equivale a acceder. No debe iniciarse sesión ni enviarse comando alguno a un sistema ajeno. En esta etapa solo se observa.

- P1. ¿Qué puertos y servicios aparecen en el dispositivo seleccionado?
- P2. ¿Qué revela su Device Identification o banner (fabricante, modelo, versión de firmware)?
- P3. ¿En qué país y ciudad se encuentra geolocalizado? ¿Qué tipo de organización aparenta ser?
- P4. ¿Por qué exponer Modbus (puerto 502) directamente a Internet constituye un problema de seguridad?

A.2. Google dorks

El perfilado de DEPSA continúa sin interactuar con sus sistemas. Numerosos PLC publican su interfaz web sin protección y quedan indexados por Google; si DEPSA tuviera alguno expuesto, aparecería de este modo. El proyecto ELITEWOLF de la NSA documentó, entre sus firmas de detección, varias rutas que sirven como dorks para localizarlos.

1. Ingresar en Google los siguientes dorks, uno por uno (Rockwell/Allen-Bradley y Siemens):

```
"/rokform/advancedDiags?pageReq=tcp"  
intitle:"Miniweb Start Page"
```

Resultado esperado: una combinación de interfaces web de PLC reales (paneles con diagnósticos y estado del equipo) y de documentación o manuales. Las páginas reales muestran datos del dispositivo en tiempo real, no texto explicativo.

h4ck3d X Security Conference

2. Abrir un par de resultados que correspondan a PLC reales (no a archivos PDF ni manuales) y observar qué información exponen.

P5. De los resultados, ¿cuáles corresponden a PLC reales expuestos y cuáles a documentación?

P6. ¿Qué información sensible muestra la página del PLC (por ejemplo, estadísticas TCP, netstat o direcciones IP internas)?

A.3. Artefactos OSINT de DEPSA: aviso de trabajo y ficha de dominio

El cliente entregó dos artefactos de OSINT ya recopilados por su equipo. Ninguno exige interactuar con sistemas de DEPSA: se analizan tal como fueron provistos.

Aviso de trabajo. Constituye una valiosa fuente de OSINT, ya que revela el stack tecnológico del entorno OT.

Técnico de SCADA, DEPSA (depsa.com.ar)
Requisitos: experiencia en Siemens S7-1200/1500
y WinCC; protocolos Modbus e IEC 60870-5-104.
Excluyente: manejo de redes industriales.

1. Leer el aviso y completar, en la hoja de trabajo:
 - PLC: _____ (indicio: la marca y la familia solicitadas)
 - SCADA / HMI: _____
 - Protocolos: _____

Ficha de dominio. Resultado de una consulta WHOIS/DNS sobre depsa.com.ar que el equipo de DEPSA documentó. Permite pasar del nombre de la empresa a su infraestructura expuesta.

Ficha OSINT de DEPSA (WHOIS / DNS de depsa.com.ar)
Registrante : Distribuidora Eléctrica Pampeana S.A.
Creado : 2009-03-12
Servidores DNS : ns1.depsa.com.ar, ns2.depsa.com.ar

Registros DNS:

depsa.com.ar	A	203.0.113.10	sitio institucional
www.depsa.com.ar	A	203.0.113.10	
correo.depsa.com.ar	A	203.0.113.25	servidor de correo
vpn.depsa.com.ar	A	198.51.100.40	acceso remoto
scada.depsa.com.ar	A	198.51.100.77	(?) acceso a SCADA

2. Analizar la ficha y señalar los hosts o servicios que ampliarían la superficie de ataque (por ejemplo, accesos remotos o sistemas de control nombrados de forma explícita).

h4ck3d X Security Conference

Resultado esperado: los subdominios revelan un servidor de correo, un acceso remoto (vpn) y, sobre todo, un host llamado scada: nombres que orientan el reconocimiento posterior hacia el entorno de control.

Práctica opcional de la técnica. La consulta WHOIS/DNS puede ensayarse, de forma independiente y solo con fines de práctica, contra cualquier dominio público autorizado (por ejemplo, el de la propia institución) mediante dnslytics.com o dnsdumpster.com. El dominio depsa.com.ar es real y resuelve en Internet pero es de otra organización.

P7. ¿Qué stack tecnológico (fabricantes, plataformas, protocolos) revela el aviso, y qué hosts o servicios de interés aparecen en la ficha de dominio (por ejemplo, accesos remotos o sistemas de control)?

Parte B. Reconocimiento activo seguro

A continuación se realiza el reconocimiento activo sobre el laboratorio de DEPSA. Para no comprometer sus equipos en producción, se trabaja contra un simulador Modbus que cada participante ejecuta en su equipo y que representa al PLC de DEPSA, con opciones orientadas a no provocar daño. En OT, el escaneo no se aborda como en IT.

B.1. Iniciar el objetivo local (representa al PLC de DEPSA)

Iniciar un simulador Modbus en el equipo propio; representará al PLC del AL-07. Elegir una de las siguientes opciones:

- Opción A (Windows, sin código):** abrir `ModRSSim2` . Queda a la escucha de Modbus/TCP en el puerto 502.
- Opción B (cualquier sistema operativo):** guardar el siguiente contenido como `sim_depsa.py` o descargalo del repo y ejecuta: `python3 sim_depsa.py`, PY `sim_depsa.py` si estas en windows :

```
from pymodbus.server import StartTcpServer
from pymodbus.datastore import (ModbusSlaveContext,
                                ModbusServerContext, ModbusSequentialDataBlock)
store = ModbusSlaveContext(
    co=ModbusSequentialDataBlock(0, [1] + [0]*99),          # bobina 0 = 1:
    interruptor AL-07 CERRADO
    hr=ModbusSequentialDataBlock(0, [132,87,7]+[0]*97),     # 13,2 kV / 8,7 A /
    alimentador 7
    zero_mode=True)    # IMPORTANTE: direccion 0 = indice 0 (sin esto, pymodbus
desfasa en 1)
ctx = ModbusServerContext(slaves=store, single=True)
StartTcpServer(context=ctx, address=("127.0.0.1", 502))
```

- 3. Verificar que esté a la escucha.** En otra terminal, ejecutar:

```
nmap -p 502 127.0.0.1
```

h4ck3d X Security Conference

Resultado esperado: 502/tcp open mbap (o, simplemente, «open»). Si indica «closed/filtered», el simulador no se inició; revisar la terminal en la que se ejecutó.

Nota: 502 es el puerto estándar de Modbus. En macOS o Linux puede requerir `sudo`; para evitarlo, utilizar el 5020 y sustituir 502 por 5020 en todos los comandos de esta práctica.

B.2. Escaneo no intrusivo (OT-safe) con nmap

Se evitan los escaneos SYN, el timing agresivo y el barrido de los 65.000 puertos. El análisis se acota a los puertos ICS habituales y se reduce el ritmo.

1. Escaneo acotado y moderado de los puertos industriales más frecuentes:

```
nmap -sT -p 502,102,80,443,44818 \
    --scan-delay 1s --max-retries 1 127.0.0.1
```

En windows:

```
nmap -sT -p 502,102,80,443,44818 --scan-delay 1s --max-retries 1 127.0.0.1
```

Salida esperada (ejemplo):

PORT	STATE	SERVICE
80/tcp	closed	http
102/tcp	closed	iso-tsap
443/tcp	closed	https
502/tcp	open	mbap
44818/tcp	closed	ethernetip-2

Observación: el simulador solo expone Modbus, de modo que aparecerá el 502 abierto y el resto cerrado. Contra un PLC real podrían observarse también abiertos el 102 (S7comm) o el 44818 (EtherNet/IP).

2. Registrar qué puertos abrió el objetivo.

Fundamento del enfoque no intrusivo. La opción `-sT` completa el handshake TCP: no deja conexiones a medio abrir, como ocurre con `-sS`, que algunas pilas TCP de PLC gestionan de forma deficiente y podrían llegar a bloquear el equipo. Los parámetros `--scan-delay` y `--max-retries` reducen la tasa de envío para no saturarlo, y acotar los puertos evita el barrido masivo que estresa al dispositivo.

P8. ¿Qué puertos abrió el escaneo en el objetivo (502, 102, otros)?

P9. ¿Por qué se emplea `-sT` en lugar de `-sS`, y para qué sirve `--scan-delay` en un entorno OT?

h4ck3d X Security Conference

B.3. Identificación con NSE

Una vez conocidos los puertos abiertos del PLC de DEPSA, se procede a identificarlo. Los scripts NSE de nmap emplean el protocolo industrial y devuelven el modelo y el firmware: la huella precisa que luego permite buscar vulnerabilidades de ese equipo.

1. Modbus (502), contra el simulador: `nmap -p 502 --script modbus-discover 127.0.0.1`
2. S7comm (102): se emplea contra un PLC Siemens real (`nmap -p 102 --script s7-info <ip>`); se mostrará en la demostración con hardware.

Salida esperada (ejemplo):

```
PORT      STATE SERVICE
502/tcp   open  mbap
| modbus-discover:
|   sid 0x1:
|_  Slave ID data: (vacío en el simulador)
```

Interpretación: confirma que en el SID 0x1 hay un dispositivo Modbus que responde. El simulador no implementa la función «Report Slave ID», por lo que ese campo aparece vacío; contra un PLC real, allí figurarían el fabricante y el modelo.

Los scripts anteriores solo funcionan con un PLC en nuestro caso en windows podemos utilizar:

```
py -c "from pymodbus.client import ModbusTcpClient as M;
c=M('127.0.0.1',port=502); c.connect();
print(c.read_holding_registers(0,10,slave=1).registers); c.close()"
```

Salida esperada: [132, 87, 7, 0, 0, 0, 0, 0, 0, 0]

Interpretación: esos registros modelan el alimentador AL-07: el valor 132 representa 13,2 kV de tensión; 87, una corriente de 8,7 A; y 7, el identificador del alimentador (AL-07). De este modo se observa el proceso de DEPSA sin haberlo modificado.

Nota: ejecutar este código con `pymodbus==3.6.9` (la versión fijada en el Bloque 0); las versiones 3.8 y posteriores modifican la API.

3. Registrar el SID que responde y, de estar disponibles, el modelo y el firmware.

P10. Según la identificación, ¿qué modelo y versión de firmware reporta el objetivo?

P11. ¿Qué devolvió la lectura y qué representan esos valores en el contexto del AL-07?

B.4. (Alternativa pasiva) Examinar el reconocimiento en una captura

Si no fue posible iniciar el simulador, o si se desea observar cómo se manifiesta este reconocimiento contra la red real de DEPSA (con sus direcciones IP, no en localhost), la captura correspondiente se incluye en el conjunto de archivos.

1. Abrir `Parte1_Practica_recon_AL07.pcap` en Wireshark.
2. En la barra de filtro (en la parte superior), escribir `modbus` y presionar Enter.

h4ck3d X Security Conference

Resultado esperado: el escaneo no intrusivo sobre la subred de DEPSA, con el 502 abierto en el LOGO (10.3.5.22) y el 102 en el PLC (10.3.5.11), seguido de una lectura Modbus de los registros del alimentador (los mismos 13,2 kV, 8,7 A e identificador AL-07).

B.6. Elaborar el inventario de activos

Con toda la información obtenida (OSINT y reconocimiento activo), se elabora el inventario de activos de DEPSA. Este registro constituye el entregable base de la evaluación y la materia prima de la priorización de riesgo de la Fase 3.

Activo	IP	Puerto	Protocolo	Fabricante	Modelo	Firmware

P12. Completar la fila con la IP, el puerto/protocolo y el fabricante/modelo/firmware del objetivo.

Demostración del instructor

Demostración del instructor. Para evidenciar la fragilidad de OT, el instructor ejecuta un escaneo agresivo (por ejemplo, `nmap -A -T5`, o `-sS / -sU`) contra uno de los PLC de DEPSA en un equipo de sacrificio. Es habitual que el equipo se bloquee, deje de responder en la HMI o requiera reinicio. Constituye el reflejo de IT que no debe trasladarse a OT: el mismo comando que en una red corporativa resulta rutinario, en este entorno puede provocar una parada de planta.

Cierre

Se cierra la Fase 1: ya se dispone del mapa de DEPSA (activos, servicios expuestos y huellas de fabricante, modelo y firmware). En la Fase 2 se analizará el tráfico capturado en la red OT de DEPSA con Wireshark, a fin de reconstruir una intrusión.

h4ck3d X Security Conference

Práctica 2. Análisis de tráfico de DEPSA (Fase 2)

Fase 2 de la evaluación. Transcurridas algunas semanas, DEPSA vuelve a contactar al equipo, esta vez por un asunto urgente. Su área de respuesta a incidentes detectó actividad anómala en la red de control y un operador afirma que un interruptor se abrió de forma autónoma. Se entregan seis capturas correspondientes a esos días. La tarea consiste en reconstruir, paso a paso y únicamente con Wireshark, cómo ingresó el atacante y hasta dónde llegó, desde la red en calma hasta el control del proceso físico.

Objetivo. Reconstruir la cadena de intrusión en la red OT de DEPSA a partir de las capturas (PCAP): desde el equipo comprometido hasta el control del PLC, identificando en cada etapa qué equipo actúa y qué acción realiza.

Antes de comenzar

- Las capturas son `practical.pcapng` a `practica6.pcapng` (del conjunto del workshop). Se abre una por ejercicio.
- Instalar el disector `s7comm-plus`: descargarlo de sourceforge.net/projects/s7commwireshark y copiar el plugin en la carpeta de plugins de Wireshark (en Wireshark: *Help* → *About* → *Folders* → *Personal Plugins*). Sin él, el tráfico de los PLC aparece como TCP genérico y el filtro `s7comm` no muestra resultados.

Direccionamiento. Toda la infraestructura del ejercicio (inventario, capturas y simulación) utiliza una sola red, 10.3.5.0/24. Es una red plana, sin separación entre IT y OT, lo que constituye en sí mismo uno de los hallazgos de la evaluación.

E1. La red en calma (`practica1.pcapng`)

Antes de buscar al atacante es necesario conocer cómo se comporta la red de DEPSA en condiciones normales: sin una línea de base, cualquier elemento parece sospechoso y, a la vez, ninguno lo es. Esta primera captura corresponde a la red de control en un día normal. Sirve para inventariar los equipos y reconocer el patrón de tráfico industrial habitual; todo lo que en las capturas siguientes se aparte de él constituirá un indicio.

1. Abrir `practical.pcapng` en Wireshark. Acceder a *Statistics* → *Endpoints* y abrir la pestaña *IPv4*. Desactivar *Limit to display filter*.

Resultado esperado: alrededor de cinco equipos dentro de la red 10.3.5.0/24: esa es la red de control de DEPSA.

h4ck3d X Security Conference

2. Pasar a la pestaña *Ethernet* para ver las direcciones MAC. A continuación, en la barra de filtro, escribir `arp.opcode==2` y presionar Enter (respuestas ARP) para correlacionar IP y MAC.

Resultado esperado: cada IP con su MAC; el nombre del fabricante suele revelar el rol (Siemens: PLC o estación; D-Link: switch; Dell: equipo del SCADA).

3. Abrir *Statistics* → *Conversations*, pestaña *TCP*, y hacer clic en el encabezado *Bytes* para ordenar.

Resultado esperado: la conversación industrial predominante es la del SCADA (10.3.5.3) con un PLC (10.3.5.12) por el puerto 102 (S7comm). Ese es el tráfico normal.

4. Examinar *Statistics* → *Protocol Hierarchy* para conocer los protocolos presentes.

P13. ¿Cuál es el rango de direccionamiento de la red de control de DEPSA?

P14. ¿Qué equipos se identifican y qué rol cumple cada uno (switch, SCADA, estación de ingeniería, PLC)?

P15. ¿Cuál es el tráfico industrial normal: qué dos equipos se comunican y por qué puerto y protocolo?

E2. La primera señal: el C&C (practica2.pcapng)

Con la línea de base presente, se busca aquello que no figuraba en ella. El primer indicio de un equipo comprometido suele ser el intento de comunicarse con un servidor del atacante en Internet (command-and-control) para recibir órdenes. La tarea consiste en localizar esa IP intrusa y comprender qué intenta hacer y por qué no lo consigue.

1. Abrir `practica2.pcapng`. En *Statistics* → *Endpoints* → *IPv4*, ordenar por la columna *Address* y buscar una dirección que no pertenezca a 10.3.5.x.

Resultado esperado: además de las 10.3.5.x, aparece una IP pública ajena a la red: 23.95.230.107.

2. Aplicar el filtro `ip.addr == 23.95.230.107` y presionar Enter. Examinar la columna *Info* y los flags TCP de cada paquete.

Resultado esperado: paquetes SYN que salen de un equipo interno hacia 23.95.230.107 por el puerto 80, sin respuesta (no hay SYN-ACK): el destino nunca contesta.

h4ck3d X Security Conference

3. Observar los puertos de origen y la columna *Time*.

Resultado esperado: alrededor de cinco intentos desde puertos de origen consecutivos (1232 a 1236), separados pocos segundos entre sí: reintentos automáticos del malware, no de una persona.

4. (OSINT, solo observación) Consultar 23.95.230.107 en una herramienta de reputación o WHOIS.

Resultado esperado: se trata de un servicio de hosting en los Estados Unidos (RackNerd / ColoCrossing, AS36352): no es infraestructura propia de una distribuidora eléctrica.

P16. ¿Qué IP aparece que no pertenece a la red de control y por qué puerto intenta comunicarse?

P17. ¿Qué equipo de DEPSA inicia esa comunicación y qué patrón presenta (puertos de origen, intervalos, respuesta)?

P18. ¿Por qué no se completa la conexión? ¿Qué control de seguridad lo explica?

P19. ¿Qué revela una consulta OSINT sobre esa IP?

E3. Búsqueda interna: el escaneo (practica3.pcapng)

El intento de salir a Internet quedó bloqueado por el firewall de DEPSA, lo cual es favorable, pero el atacante permanece en la red. Un atacante que no puede salir dirige su atención hacia el interior: su paso siguiente es descubrir qué otros equipos existen en la red de control para desplazarse hacia ellos. Esta captura muestra ese reconocimiento interno.

1. Abrir `practica3.pcapng` y examinar *Statistics* → *Endpoints* → *IPv4*, comparándolo con la línea de base de E1.

Resultado esperado: aparece un equipo que no figuraba en la red en calma: el PLC-1 (10.3.5.11), descubierto durante el escaneo.

2. Aplicar el filtro `arp` y presionar Enter para observar el barrido previo al escaneo.

Resultado esperado: la estación de ingeniería (10.3.5.5) consultando «¿quién tiene la 10.3.5.X?» por toda la subred: está buscando equipos activos.

h4ck3d X Security Conference

3. Abrir *Statistics* → *Conversations* → *TCP* y ordenar por la columna del puerto de destino (*Port B*).

Resultado esperado: numerosos intentos de conexión desde 10.3.5.5 hacia puertos secuenciales de otros equipos: el patrón característico de un escaneo de puertos.

P20. Aparece un equipo que no se había observado antes. ¿Cuál es?

P21. ¿Qué equipo realiza el escaneo y cómo se confirma?

P22. ¿Qué tipo de actividad es y contra qué objetivos se dirige?

E4. Reconocimiento del PLC: Read SZL (*practica4.pcapng*)

El atacante ya conoce qué equipos existen; ahora los interroga mediante su propio protocolo. S7comm dispone de una función, Read SZL, que un PLC Siemens responde sin solicitar autenticación: devuelve el modelo, el firmware y el número de serie. Equivale a obtener la huella de identificación de cada PLC; con esos datos, el atacante busca posteriormente vulnerabilidades específicas de ese modelo y firmware.

1. Abrir *practica4.pcapng*. En la barra de filtro, escribir *s7comm* y presionar Enter. (Si no aparece ningún resultado, falta el plugin *s7comm-plus*; véase «Antes de comenzar».)
2. Hacer clic con el botón derecho sobre un paquete S7comm y seleccionar *Follow* → *TCP Stream*, para seguir la conversación de la estación (10.3.5.5) con el PLC por el puerto 102.
3. En los paquetes de respuesta, expandir *S7COMM* → *Data* y localizar el campo *SZL-ID*.

Resultado esperado: consultas Read SZL con los identificadores 0x0011 (identificación de módulo y firmware) y 0x001c (serie e identificación); en la respuesta figura el modelo, por ejemplo 6ES7 511-1AK01-0AB0, firmware V2.0.1, familia S7-1500.

P23. ¿Qué secuencia S7comm ejecuta contra los PLC (qué funciones y en qué orden)?

P24. ¿Qué información obtiene con Read SZL (identificadores 0x0011 y 0x001c) y a qué comando de nmap equivale?

P25. ¿Para qué le resulta útil al atacante este reconocimiento?

h4ck3d X Security Conference

E5. Acceso al SCADA: fuerza bruta de VNC (practica5.pcapng)

Con el mapa completo, el atacante se dirige al objetivo de mayor valor: la pantalla del SCADA, desde la cual se opera toda la red. Al no disponer de la contraseña, prueba numerosas combinaciones mediante VNC (el escritorio remoto). Esta captura muestra ese ataque de fuerza bruta y, sobre todo, permite determinar si tuvo éxito, ya que de ello depende todo lo que sigue.

1. Abrir `practica5.pcapng`. Aplicar el filtro `vnc` y presionar Enter. En *Statistics* → *Conversations* → *TCP* se observa la actividad en el puerto 5900 entre la estación (10.3.5.5) y el SCADA (10.3.5.3).
2. Observar el handshake VNC al inicio de cada intento: aparece el banner `RFB 003.008`. Atender a los puertos de origen y a los tiempos.

Resultado esperado: una serie de intentos de conexión desde puertos de origen consecutivos (1396 a 1401), separados pocos segundos: el patrón de la fuerza bruta.

3. Comparar de qué modo finaliza cada intento.

Resultado esperado: los primeros cinco intentos fallan y la conexión se cierra (RST); el sexto se mantiene abierto: esa fue la contraseña correcta. El atacante accedió al SCADA.

P26. ¿Qué protocolo y puerto se emplean y entre qué equipos?

P27. ¿Qué patrón indica fuerza bruta y cuál fue el resultado?

P28. ¿Cómo se distingue en los paquetes un intento fallido de uno exitoso?

E6. El clic que alcanza el proceso (practica6.pcapng)

Esta es la captura que da sentido a todo el conjunto. El atacante ya se encuentra dentro del SCADA. Lo que se observa es un clic en la pantalla de la HMI que, milisegundos después, se convierte en una orden real al PLC. Es el momento preciso en que el ataque informático trasciende al mundo físico: el operador que vio el interruptor abrirse «de forma autónoma» observó, en realidad, este evento. Constituye la evidencia más importante del informe a DEPSA.

1. Abrir `practica6.pcapng`. Aplicar el filtro `vnc` y localizar los paquetes *Client pointer event* (posición y botones del mouse sobre la pantalla del SCADA).
2. Situar en el `frame 1126` y compararlo con el `frame 1127`. Expandir la capa *VNC* en cada uno y observar el *button mask* y las coordenadas.

Resultado esperado: en el `frame 1126` un botón del mouse figura presionado y en el 1127, liberado, en la misma posición (aproximadamente 518, 261): en conjunto constituyen un clic sobre un control de la pantalla.

h4ck3d X Security Conference

3. Quitar el filtro y observar los frames inmediatamente posteriores (en torno al `frame 1129`).

Resultado esperado: alrededor de 8 ms después del clic, el SCADA (10.3.5.3) se comunica con el PLC (10.3.5.12) por el puerto 102 (COTP/S7comm): el clic en la pantalla se transformó en una orden al proceso.

P29. ¿Qué tipo de paquetes VNC se observan ahora y qué representan?

P30. Al comparar el frame 1126 con el 1127, ¿qué cambia y qué acción representa?

P31. ¿Qué equipos interactúan inmediatamente después del clic, por qué protocolo y puerto, y con qué latencia? ¿Por qué constituye la evidencia más crítica?

Cierre

El análisis de las capturas permitió reconstruir la intrusión a partir del primer artefacto observable: el intento de comunicación con el servidor de comando y control, bloqueado por el firewall (E2). A partir de ahí, la cadena continúa con el escaneo interno (E3), el reconocimiento de los PLC mediante Read SZL (E4), la fuerza bruta de VNC contra el SCADA (E5) y, por último, el clic en la HMI que alcanza el PLC (E6). El vector de entrada (el correo de phishing y el código malicioso que habría infectado la estación de ingeniería) queda fuera de estas capturas: es el origen presumido del incidente, no una etapa reconstruida a partir de la evidencia. Distinguir lo que la evidencia demuestra de lo que se infiere forma parte del trabajo forense. En la Fase 3 se analizará el impacto sobre el proceso (una escritura Modbus que abre el interruptor AL-07) y se priorizarán los hallazgos para el informe a DEPSA.

Actividad opcional: informe. Si el tiempo lo permite, redactar tres o cuatro conclusiones, en lenguaje accesible para un lector no técnico, tal como se presentarían en el informe a DEPSA (con una estructura del tipo UNE 197001).

h4ck3d X Security Conference

Práctica 3. Impacto y riesgo en DEPSA (Fase 3)

Última fase. Ya se conoce qué activos existen (Fase 1) y cómo ingresó el atacante (Fase 2). Restan dos tareas: demostrar, de forma controlada, el impacto sobre el proceso de DEPSA y, a continuación, convertir todo lo hallado en un informe de riesgo priorizado para el cliente.

Objetivo. Demostrar cómo una escritura Modbus sin autenticación abre el interruptor del alimentador AL-07, y priorizar los hallazgos de la evaluación mediante la matriz de riesgo de la norma IEC 62443.

Parte A. El impacto: abrir el interruptor del AL-07 (≈10 min)

El LOGO modela el interruptor del alimentador AL-07, que suministra energía a un barrio y a un hospital. Su lógica mantiene el interruptor cerrado (energizado). El problema reside en que la bobina que comanda el interruptor puede escribirse por Modbus sin autenticación: al forzarla a 0, el interruptor abre y el alimentador queda sin energía.

La lógica, en síntesis. En condiciones normales, la bobina de mando vale 1 (cerrado, con energía) y está asignada a la bobina Modbus 0, accesible desde la red. Escribir 0 equivale a abrir el interruptor (sin energía). El instructor muestra el programa ladder real en el LOGO.

A.1. Examinar el ataque en la captura

Antes de reproducir la acción, conviene observar cómo se manifiesta el ataque sobre la red de DEPSA. Esta captura corresponde a la escritura Modbus que abrió el AL-07: los mismos tres pasos que se reproducirán a continuación. El atacante lee el estado del interruptor, fuerza la salida y vuelve a leer para confirmar que quedó abierto.

1. Abrir `Parte3_pratica_write_AL07.pcap` en Wireshark. En la barra de filtro, escribir `modbus` y presionar Enter.
2. Recorrer la sesión con el LOGO (10.3.5.22, puerto 502) observando la columna *Info*.

Resultado esperado: tres etapas: *Read Coils (estado = 1, cerrado)*, *Write Single Coil con valor 0x0000 sobre la bobina 0 (función 5)* y una nueva *Read Coils que ahora devuelve 0 (abierto)*.

P32. ¿Qué función Modbus emplea el atacante para forzar la apertura y qué valor escribe?

P33. ¿Cómo confirma el atacante que el interruptor quedó abierto?

h4ck3d X Security Conference

A.2. Reproducir el ataque contra el simulador

A continuación, debes enviar al simulador (que representa al PLC del AL-07) exactamente la misma orden que el atacante, sin usuario ni contraseña. El propósito no es dañar, sino comprobar de primera mano que el protocolo no exige credencial alguna para abrir un interruptor que deja a un barrio sin suministro.

```
from pymodbus.client import ModbusTcpClient
c = ModbusTcpClient("127.0.0.1", port=502)
c.connect()
print("Estado:", c.read_coils(0, 1, slave=1).bits[0]) # True = cerrado
c.write_coil(0, False, slave=1) # forzar APERTURA
print("Ahora :", c.read_coils(0, 1, slave=1).bits[0]) # False = abierto
c.close()
```

Nota: ejecutar este código con pymodbus==3.6.9 (la versión fijada en el Bloque 0); las versiones 3.8 y posteriores modifican la API.

P34. Fue posible escribir la salida sin credencial alguna. ¿Qué revela esto sobre la seguridad de Modbus?

A.3. Demostración del instructor (hardware)

Para no limitar el ejercicio a la teoría, el instructor traslada la misma orden al hardware real del banco de pruebas.

Demostración del instructor. El instructor ejecuta la misma escritura contra el LOGO real del banco. La lámpara conectada a la salida del interruptor se apaga: el AL-07 abrió y el barrio quedó sin energía. Es el escenario de Ucrania (2015) a escala reducida.

h4ck3d X Security Conference

Parte B. El riesgo: priorizar los hallazgos (≈10 min)

Una evaluación de seguridad rigurosa no concluye en «se puede vulnerar», sino en un informe que ayuda al cliente a decidir qué corregir primero. En esta parte se priorizan los hallazgos de DEPSA mediante la matriz de riesgo de la norma IEC 62443.

B.1. Los hallazgos de la evaluación

Desde la perspectiva del informe final, conviene consolidar en una lista lo que la evaluación detectó: son los hallazgos que DEPSA necesita comprender para decidir qué reforzar en primer lugar.

- Modbus sin autenticación en el LOGO del AL-07: permite abrir el interruptor (Fase 3).
- VNC con contraseña débil en el SCADA: acceso mediante fuerza bruta (Fase 2).
- S7comm sin autenticación en el PLC: permite el reconocimiento y el envío de comandos (Fase 2).
- Ausencia de segmentación IT/OT: la estación de ingeniería tenía salida directa a Internet, lo que habilitó su compromiso y el intento de comunicación con el servidor de comando y control observado en la Fase 2.

B.2. La matriz de riesgo

El riesgo se define como el producto del impacto por la probabilidad, valorados ambos de 1 a 5. El impacto se determina por la peor consecuencia posible (seguridad, ambiente, economía o reputación).

Impacto ↓ / Prob. →	1 Improb.	2 Rara	3 Posible	4 Probable	5 Casi seguro
5 Crítico	5	10	15	20	25
4 Mayor	4	8	12	16	20
3 Moderado	3	6	9	12	15
2 Menor	2	4	6	8	10
1 Trivial	1	2	3	4	5

A partir del valor de riesgo (de 1 a 25) se determina el nivel de seguridad objetivo (SL-T):

- De 1 a 5 corresponde SL-T 0; de 6 a 10, SL-T 1; de 11 a 15, SL-T 2; de 16 a 20, SL-T 3; de 21 a 25, SL-T 4.

h4ck3d X Security Conference

B.3. Mini-matriz de riesgo: los activos de DEPSA

Se trasladan los hallazgos a los activos del inventario de DEPSA. Se incluyen dos filas resueltas a modo de ejemplo; las cuatro restantes deben completarse asignando impacto y probabilidad y calculando el riesgo (impacto por probabilidad) y el SL-T.

Activo	Amenaza principal	Imp.	Prob.	Riesgo	SL-T
RTU-LOGO (AL-07)	Modbus sin autenticación: apertura del interruptor	5	5	25	4
SCADA-01 (WinCC)	VNC con contraseña débil: control del proceso	5	4	20	3
PLC-2 (S7-1500)	S7comm sin autenticación: control del proceso				
PLC-1 (S7-1500)	S7comm sin autenticación: comandos y lógica				
EWS-01 (estación de ingeniería)	Equipo comprometido, pivote hacia OT				
SW-01 (D-Link)	Switch sin gestión: sin visibilidad ni segmentación				

P35. Completar las cuatro filas restantes (PLC-2, PLC-1, EWS-01, SW-01): impacto, probabilidad, riesgo y SL-T.

P36. ¿Cuál es el activo de mayor riesgo y por qué? ¿Cuál debería remediarse primero?

P37. Proponer una contramedida concreta para ese activo.

Al finalizar este workshop habrás:

reconocido el entorno de DEPSA, reconstruido la intrusión, demostrado el impacto y priorizar el riesgo. Ese es, a escala reducida, el trabajo de un equipo de seguridad OT, y coincide con lo ocurrido en Ucrania, donde la apertura de interruptores dejó a cientos de miles de personas sin suministro eléctrico. La única diferencia entre aquel ataque y este ejercicio es la autorización.